

Protocolli SSL e TLS

Alfredo De Santis

Dipartimento di Informatica
Università di Salerno

ads@dia.unisa.it

<http://www.dia.unisa.it/professori/ads>

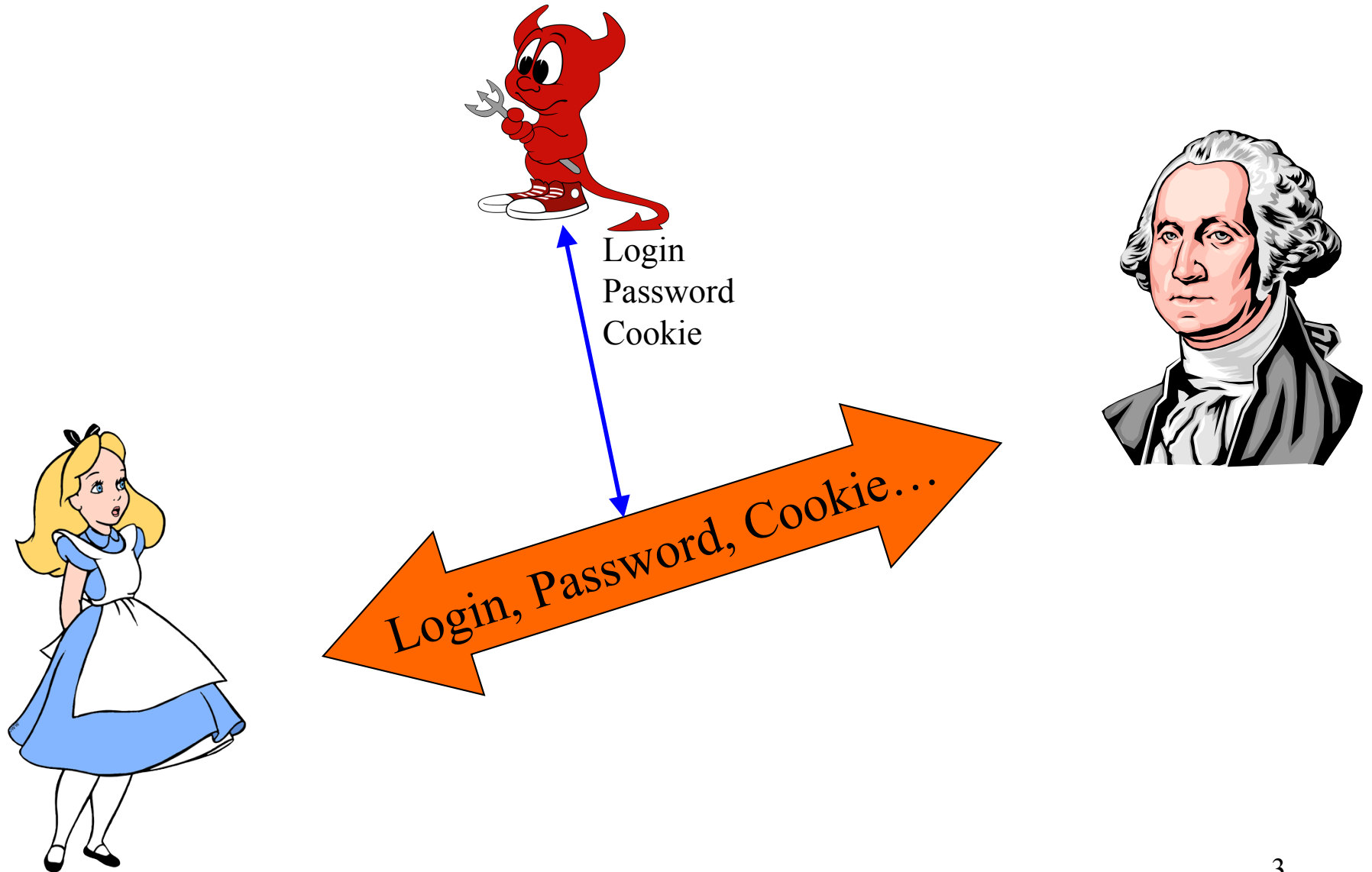


Maggio 2017

Motivazioni

- TCP/IP consente di leggere ed alterare i dati che vengono inviati in rete
- Le informazioni scambiate tra due applicazioni su Internet passano attraverso varie entità
- Molti servizi richiedono il supporto delle stesse proprietà
 - Autenticazione
 - Integrità
 - Confidenzialità
 - Etc.

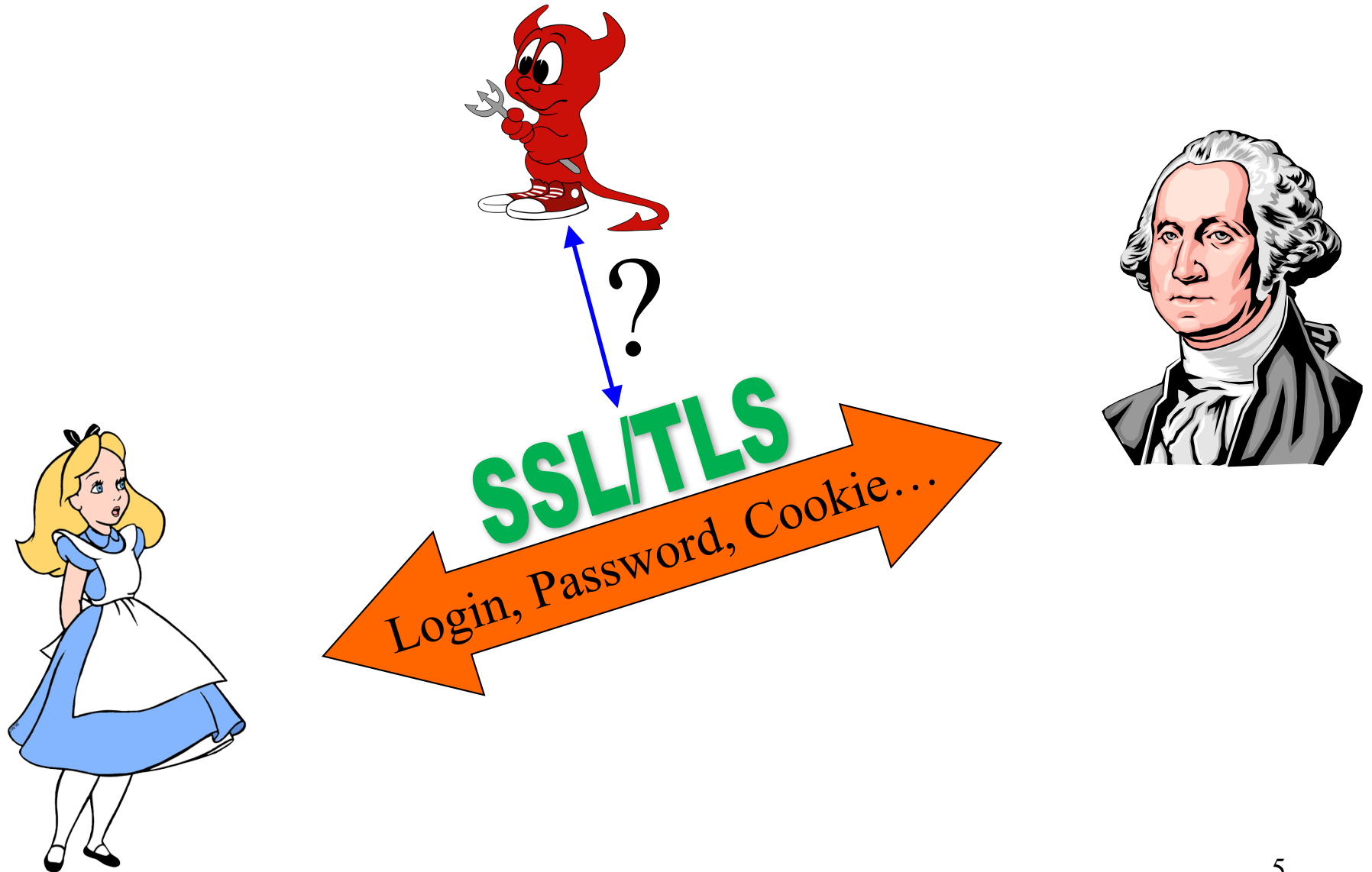
TCP/IP



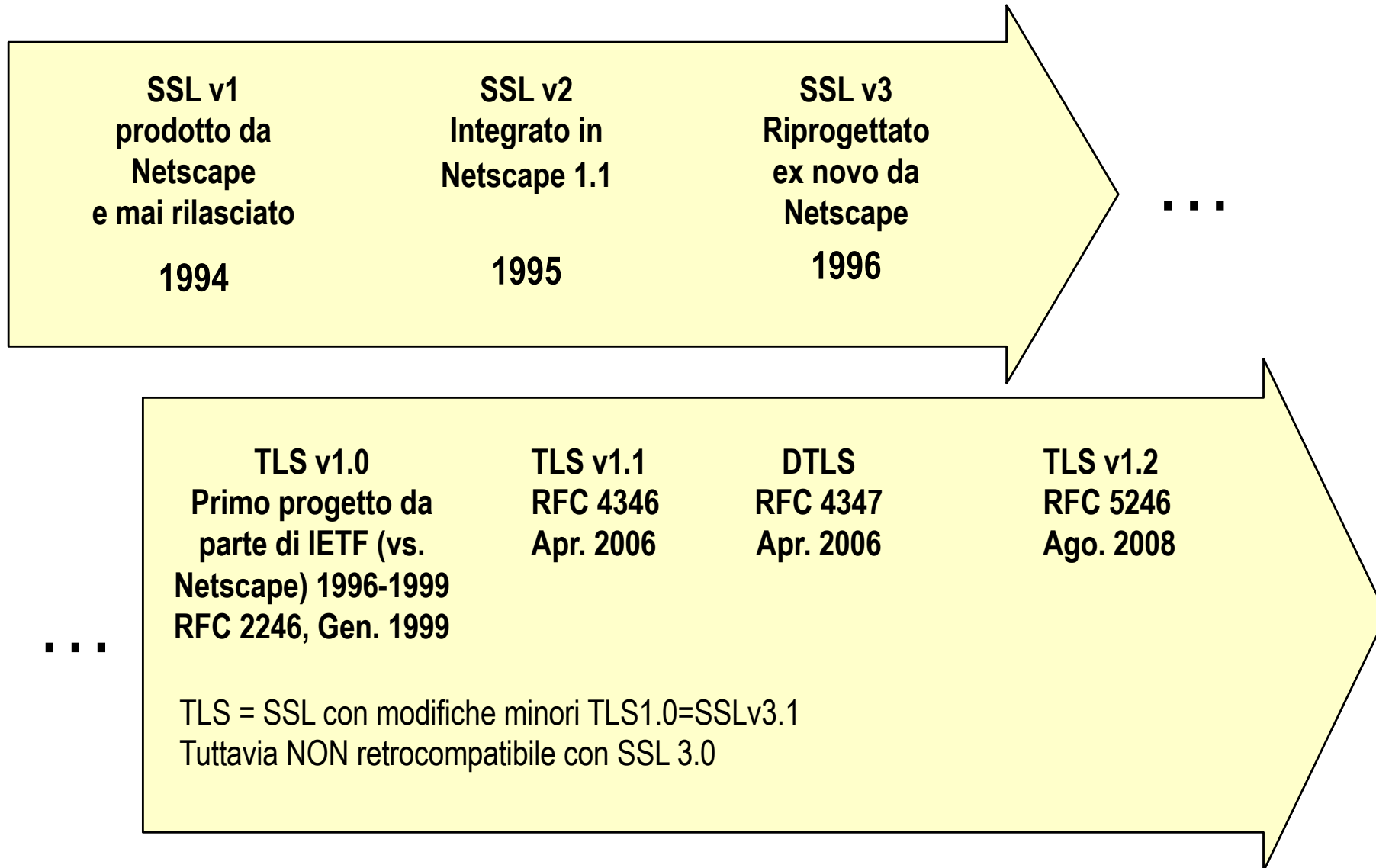
I protocolli SSL/TLS

- **SSL** = Secure Socket Layer
 - Socket = concetto di UNIX per network API
- **TLS** = Transport Layer Security
- **DTLS** = Datagram Transport Layer Security
- Offrono meccanismi di sicurezza alle applicazioni che usano il protocollo TCP
- Sono in grado di rendere sicuri numerosi protocolli applicativi
 - HTTP, NNTP, POP3, IMAP, Etc.

TCP/IP



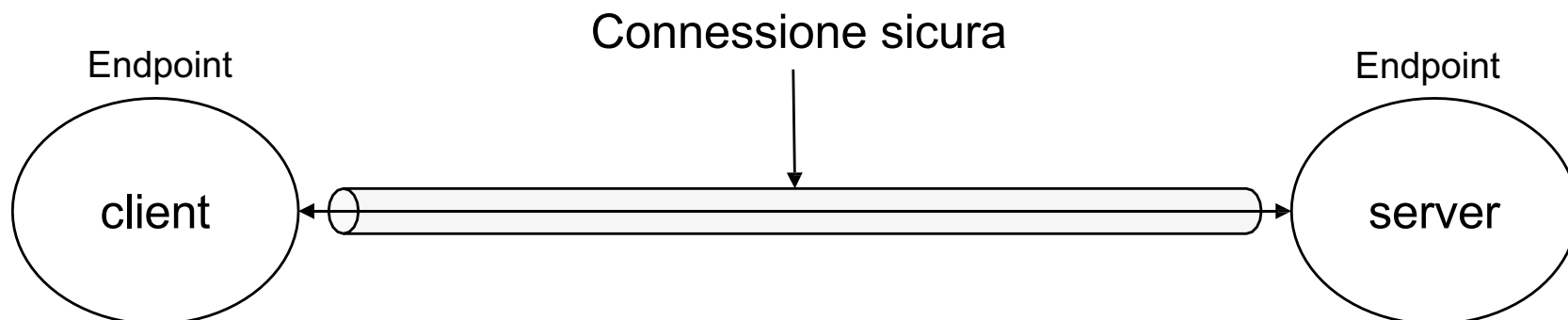
Storia di SSL/TLS



TLS v1.3 ancora in versione draft

Caratteristiche di SSL/TLS

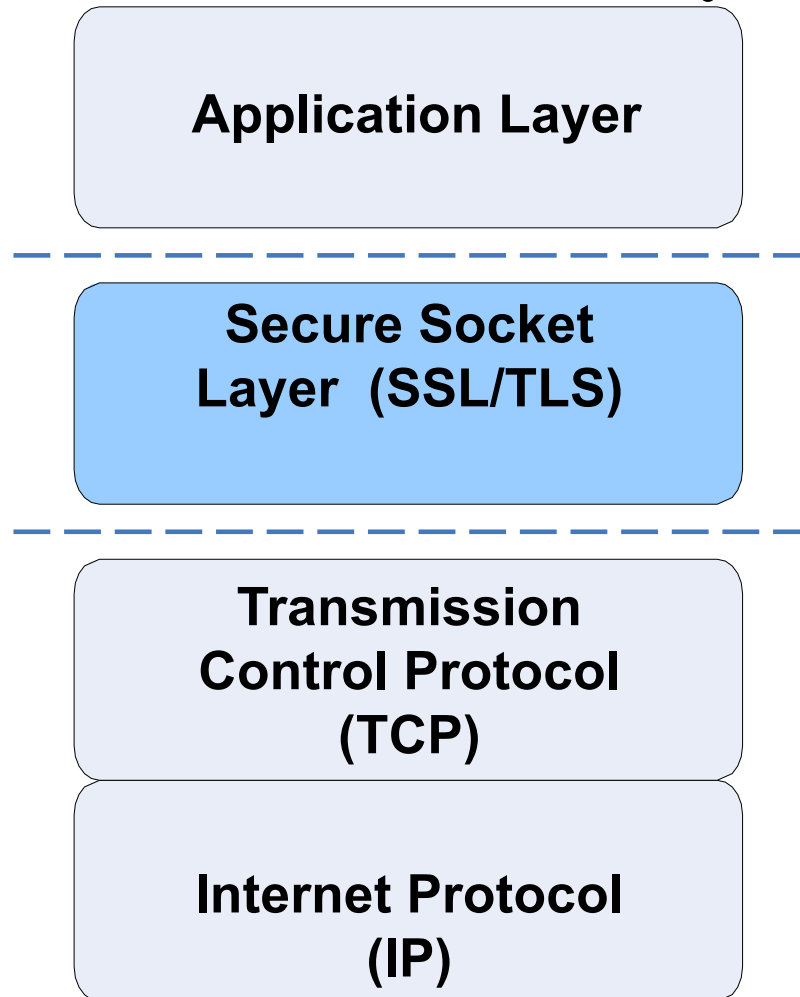
- Fornisce l'autenticazione per applicazioni server e client
- Cifra i dati prima di inviarli su un canale pubblico
- Garantisce l'integrità dell'informazione
- I principali algoritmi crittografici utilizzati vengono negoziati tra le parti
- È stato progettato per essere efficiente



Ambiti di Utilizzo di SSL/TLS

- **Commercio elettronico**
 - Ordinazioni: le form con cui si ordina un prodotto vengono inviate usando SSL/TLS
 - Pagamenti: quando viene inserito un numero di carta di credito, l'invio dei dati avviene usando SSL/TLS
- **Accesso sicuro ad informazioni**
 - La consultazione di informazioni accessibili solo da utenti "qualificati"
 - L'invio di password o altri dati riservati
- **E molto altro ancora...**

Dove Opera SSL/TLS



- SSL/TLS opera tra il livello applicativo e TCP
- Fornisce una interfaccia simile a quella fornita da TCP
- In teoria può essere usato da tutte le applicazioni basate su TCP, in maniera trasparente

Componenti di SSL/TLS

➤ Handshake Protocol

- Permette alle parti di negoziare i diversi algoritmi necessari per la sicurezza delle transazioni
- Consente l'eventuale autenticazione tra le parti

➤ Record Protocol

- Si occupa della compressione, del MAC e della cifratura

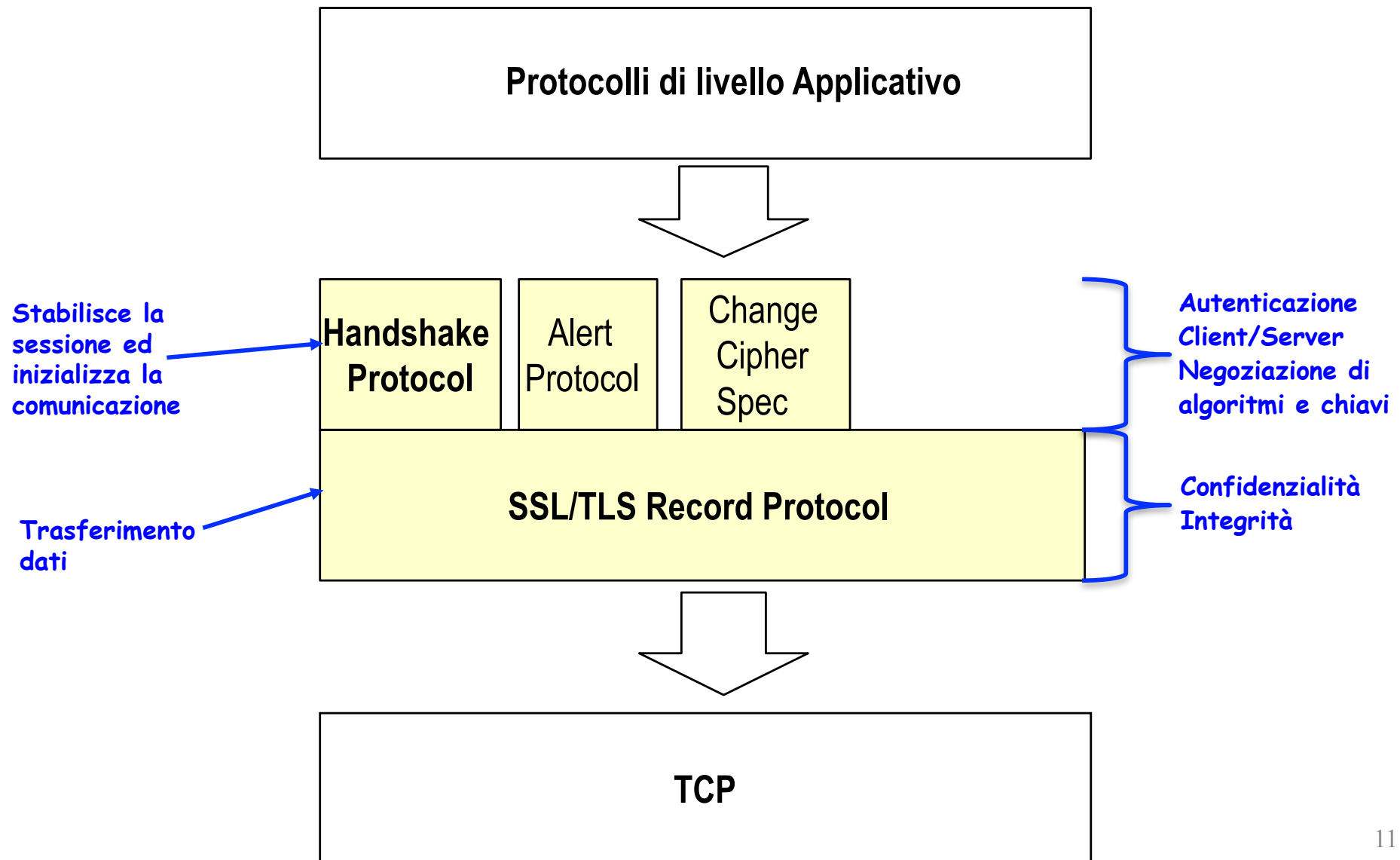
➤ Change Cipher Spec Protocol

- Impone l'esecuzione di un nuovo handshake per rinegoziare i parametri di sicurezza e ripetere l'autenticazione

➤ Alert Protocol

- Notifica situazioni anomale o segnala eventuali problemi

SSL/TLS Protocol Stack



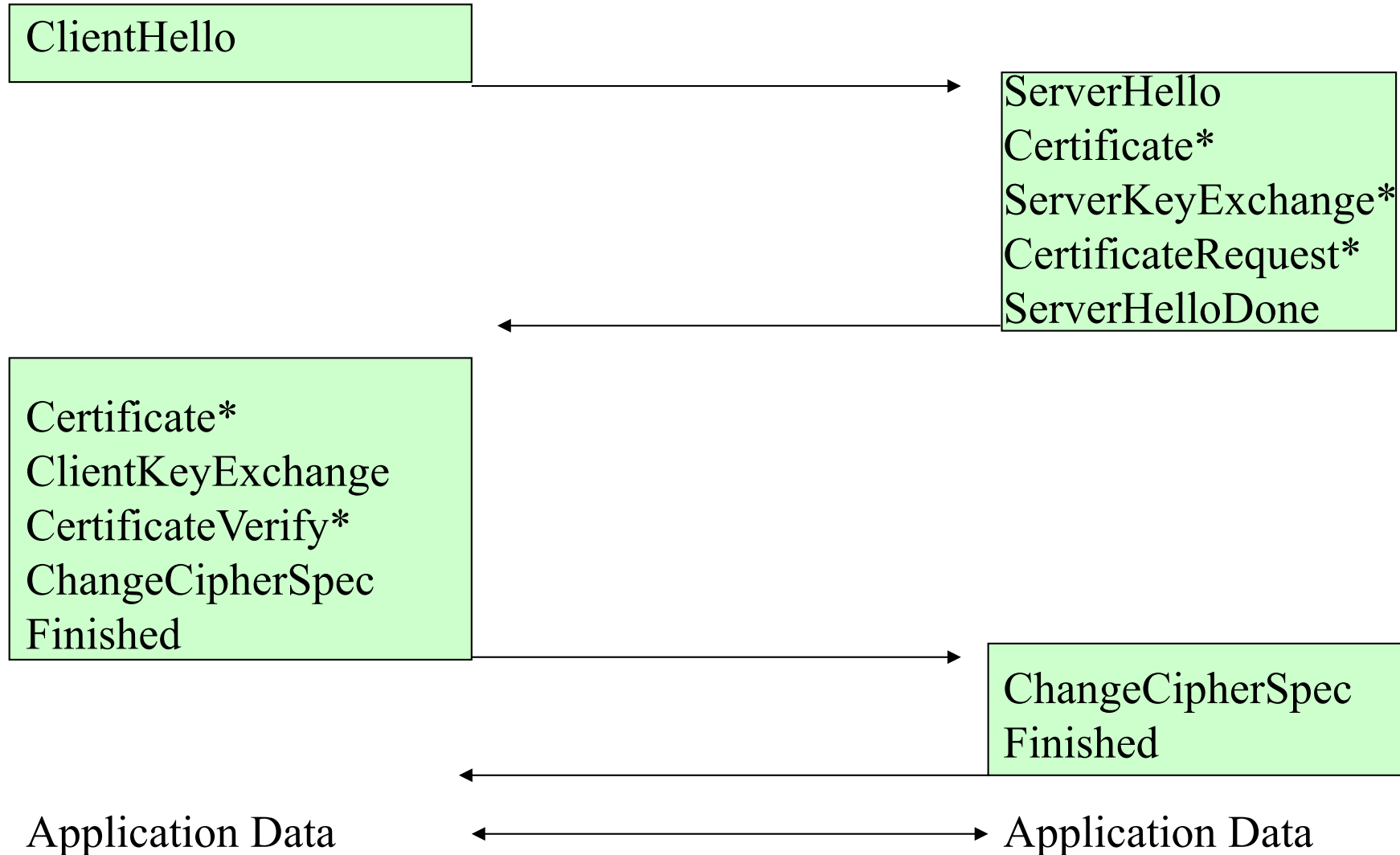
Handshake Protocol

- Utilizzato dalle due parti
 - Client e server
- Permette di
 - Negoziare la versione del protocollo e l'insieme degli algoritmi crittografici da utilizzare (ciphersuite)
 - Interoperabilità tra le diverse implementazioni del protocollo
 - Stabilire le chiavi crittografiche da utilizzare
 - Autenticare client e server (opzionale)
 - Utilizzo di certificati digitali per ottenere la chiave pubblica dell'altro endpoint e verificarne l'identità

Ciphersuite di SSL

- Gli algoritmi crittografici usati da SSL/TLS dipendono dalla ciphersuite su cui si sono accordate le parti
- La ciphersuite e gli algoritmi di compressione sono negoziati mediante l'handshake protocol
- Una ciphersuite definisce
 - Funzione hash usata dall'HMAC (ad es., SHA)
 - Schema di cifratura simmetrica (ad es., 3DES_EDE_CBC)
 - Sia block cipher che stream cipher
 - Schema per l'accordo/scambio di chiavi (ad es., RSA oppure DH)
- Esempi
 - **TLS_NULL_WITH_NULL_NULL**
 - **TLS_RSA_WITH_3DES_EDE_CBC_SHA**
 - **TLS_RSA_WITH_RC4_128_SHA**

Handshake



*messaggio opzionale

Sessione Sicura

- Una sessione sicura rappresenta una sequenza di valori che possono essere utilizzati con SSL/TLS
 - Valori segreti (calcolati durante l'handshake)
 - Ciphersuite (stabilita durante l'handshake)
- Stabilire tutti i parametri ogni volta che c'è una connessione può essere inefficiente
 - Una sessione può sopravvivere quindi tra più connessioni

Costo di una Sessione

- Lato client
 - Generazione di valori random
 - Verificare il certificato digitale del server
 - Generare dei valori random per la chiave
 - Cifrare i valori random con la chiave pubblica del server
 - Calcolare la chiave attraverso degli hash
- Lato server
 - Generazione di valori random
 - Decifrare i valori inviati dal client
 - Verificare il certificato del client e la firma di una challenge
 - Calcolare la chiave attraverso degli hash



Un elevato rate di accessi mette in crisi il server

Informazioni di Stato relative a Sessione e Connessione

➤ Sessione

- **Session ID**
- **Certificati** - identità degli endpoint
- **Algoritmo di compressione e ciphersuite**
- **Master key** - seme per la derivazione delle varie chiavi utilizzate dal protocollo
- **Riesumabile** - Valore booleano che indica se la sessione può essere utilizzata in più connessioni

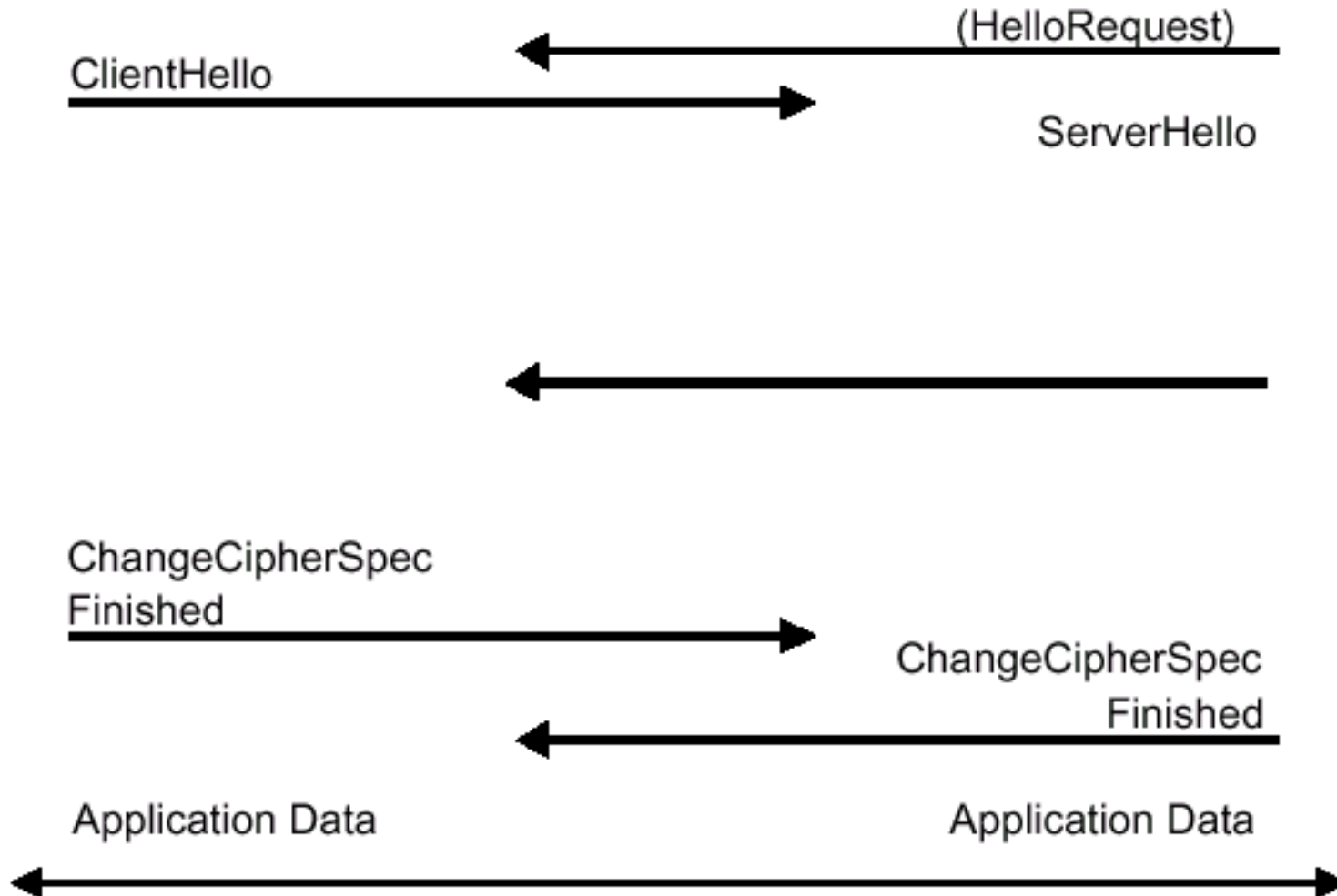
➤ Connessione

- **Numeri di sequenza**
- **Chiavi MAC**
- **Chiavi di cifratura**
- **Vettori di inizializzazione (IV)**
- **Chiavi ed IV** sono creati in base alla **Master key**
- Sono create chiavi diverse per ogni connessione
 - Anche se basate sulla stessa sessione

Handshake: Riesumazione

- Il protocollo di handshake può essere eseguito in forma abbreviata, per riesumare una sessione precedentemente stabilita
 - Non è richiesta l'autenticazione
 - Non è richiesto lo scambio di "*key material*"
 - Le sessioni sono riesumate a partire dal loro stato precedente

Handshake: Riesumazione



{Client, Server}Hello, ServerHelloDone

- Sono i primi messaggi inviati per stabilire i parametri di una sessione
 - Permettono di scambiare valori random generati da entrambe le parti
 - Permettono alle parti di accordarsi su una ciphersuite
 - Verificano se è necessario riesumare una sessione iniziata in precedenza
 - Sono tutti obbligatori
- Il compito di *ServerHelloDone* è quello di comunicare che il blocco di messaggi del server è terminato

ClientHello

```
struct {  
    ProtocolVersion client_version;  
    Random random;  
    SessionID session_id;  
    CipherSuite cipher_suites;  
    CompressionMethod compression_methods;  
} ClientHello;
```

ClientHello

- ClientHello
 - **client_version**: versione più recente del protocollo supportata dal client
 - **random**: timestamp di 4-byte
 - **session_id**
 - Valore diverso da zero per una nuova connessione sulla sessione corrente
 - Valore uguale a zero per una nuova connessione su una nuova sessione
 - **cipher_suites**: lista ordinata degli algoritmi crittografici supportati dal client
 - **compression_methods**: lista ordinata degli algoritmi di compressione supportati dal client

ServerHello

```
struct {  
    ProtocolVersion server_version;  
    Random random;  
    SessionID session_id;  
    CipherSuite cipher_suite;  
    CompressionMethod compression_method;  
} ServerHello;
```

ServerHello

- **ServerHello**
 - **random**
 - Valore random di 32-byte
 - **session_id**
 - Valore nuovo oppure relativo ad una sessione precedente
 - **server_version**
 - MIN(versione suggerita dal client, versione più alta supportata dal server)
 - **cipher_suite**: ciphersuite scelta
 - **compression_method**: algoritmo di compressione scelto

Autenticazione: *Certificate*, *Certificate{Request, Verify}*

- Sono i messaggi che consentono alle parti di autenticarsi
 - Il messaggio *Certificate* contiene una lista di certificati
 - Il certificato del server deve essere conforme all'algoritmo di autenticazione specificato nella ciphersuite concordata
 - Il certificato del client deve essere inviato solo se c'è un messaggio *CertificateRequest*

Autenticazione: Certificate, Certificate{Request, Verify}

- L'eventuale certificato inviato dal client deve essere conforme alle specifiche indicate nel messaggio *CertificateRequest*
 - Ad es., potrebbero esserci vincoli sul tipo di certificato e la Certification Authority che lo hanno rilasciato
- L'invio dei certificati non è obbligatorio, ma quello server può essere necessario
 - Dipende dalla ciphersuite concordata

{Client, Server}KeyExchange

- Il server invia il messaggio *ServerKeyExchange* se il proprio certificato non è adeguato al tipo di autenticazione stabilito nella chipersuite
- Il messaggio *ClientKeyExchange* è obbligatorio
 - Con esso le parti hanno le informazioni necessarie per poter calcolare la chiave di cifratura simmetrica da utilizzare in seguito all'handshake

ServerKeyExchange

```
struct {  
    select (KeyExchangeAlgorithm) {  
        case diffie_hellman:  
            ServerDHParams params;  
            Signature signed_params;  
        case rsa:  
            ServerRSAParams params;  
            Signature signed_params;  
    };  
} ServerKeyExchange;
```


ClientKeyExchange

```
struct {  
    select (KeyExchangeAlgorithm) {  
        case rsa: EncryptedPreMasterSecret;  
        case diffie_hellman: ClientDiffieHellmanPublic;  
    } exchange_keys;  
} ClientKeyExchange;  
  
struct {  
    ProtocolVersion client_version;  
    opaque random[48];  
} PreMasterSecret;
```

CertificateVerify

- Il messaggio *CertificateVerify* viene inviato dal client solo se quest'ultimo ha inviato il proprio certificato al server
 - Contiene una firma digitale dell'hash dei messaggi scambiati fino a quel momento
- Il messaggio *ServerKeyExchange* oppure la decifratura di *ClientKeyExchange* vengono usati con il messaggio *Finished* per l'identificazione del server

ChangeCipherSpec - Finished

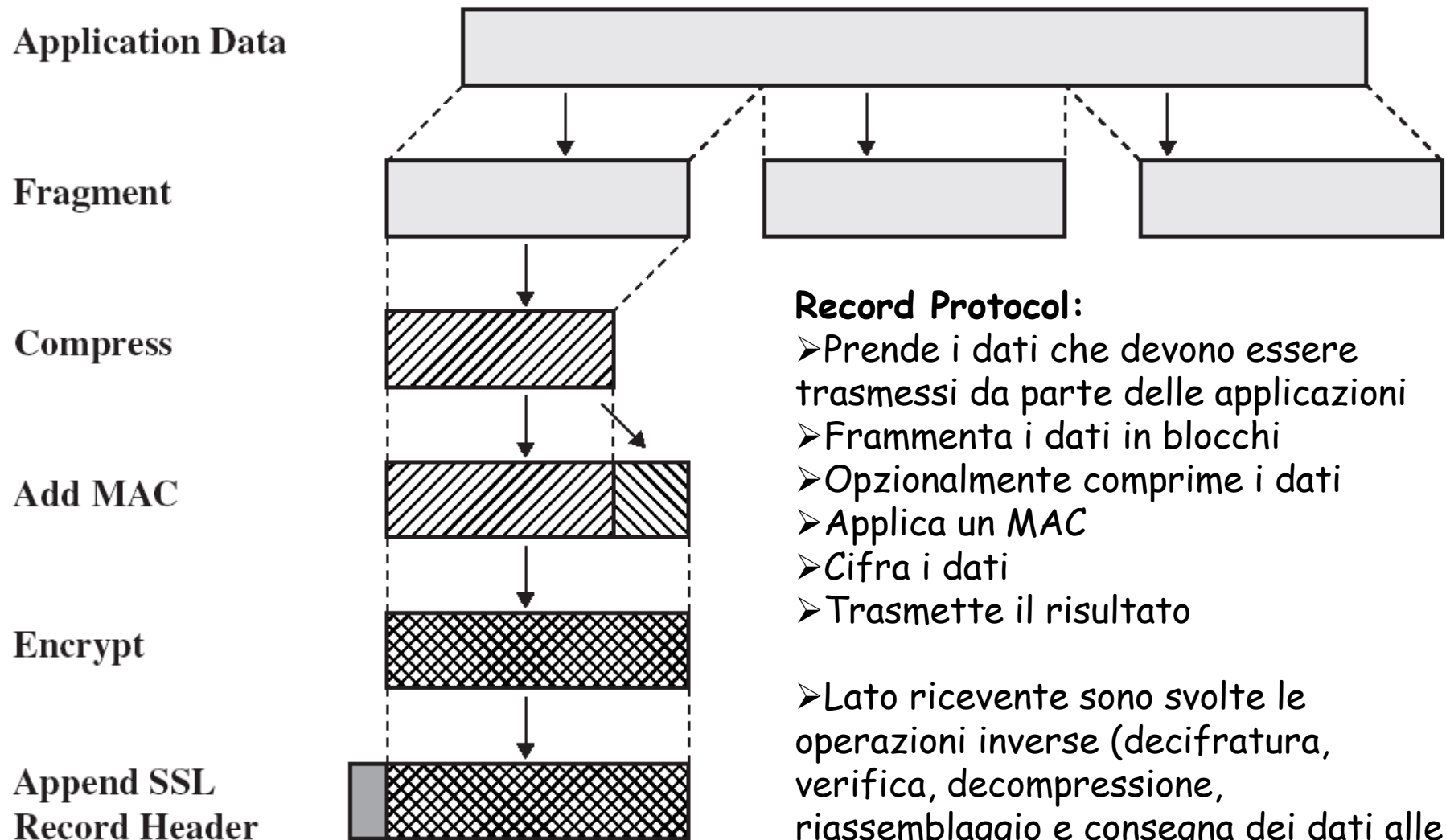
- Mediante il messaggio *ChangeCipherSpec* ogni parte indica all'altra che sta per usare gli algoritmi e le chiavi appena negoziate
- I messaggi *Finished* sono di testing
 - Sono i primi messaggi che vengono inviati utilizzando algoritmi e chiavi negoziate durante le fasi precedenti

ChangeCipherSpec, Finished

```
struct {  
    enum { change_cipher_spec(1), (255) } type;  
} ChangeCipherSpec;
```

```
struct {  
    opaque md5_hash[16];  
    opaque sha_hash[20];  
} Finished;
```

Record Protocol



Record Protocol:

- Prende i dati che devono essere trasmessi da parte delle applicazioni
- Frammenta i dati in blocchi
- Opzionalmente comprime i dati
- Applica un MAC
- Cifra i dati
- Trasmette il risultato

➤ Lato ricevente sono svolte le operazioni inverse (decifratura, verifica, decompressione, riassettaggio e consegna dei dati alle applicazioni)

Change Cipher Spec Protocol

- È utilizzato per aggiornare la ciphersuite in uso tra client e server
- Il protocollo consiste in un unico messaggio, inviato da una delle due parti all'altra
 - Il messaggio è dato da un singolo byte di valore 1



Alert Protocol

- Usato da una parte per trasmettere messaggi di alert all'altra
- Ciascun messaggio è caratterizzato da un
 - Livello di severità
 - warning o fatal
 - Tipo di alert
 - unexpected message, bad record mac, decompression failure, handshake failure, illegal parameter, close notify, no certificate, bad certificate, unsupported certificate, certificate revoked, certificate expired, certificate unknown, etc

Utilizzo di SSL/TLS

HTTPS: pagine WEB sicure

The screenshot shows the Amazon Italy homepage with a secure HTTPS connection. The browser address bar displays 'https://www.amazon.it' with a 67% security indicator. The page features a large banner for Kindle devices, including the Kindle Paperwhite, with prices starting from 59.99€ and 129.99€. Below the banner, there are several promotional tiles: a 'Benvenuto' (Welcome) message, a 'Categorie in evidenza' (Featured Categories) section highlighting cameras, books, and DVDs, a 'Vestiti Donna' (Women's Clothing) section, and a 'Feedback annuncio' (Feedback announcement) section. The page also includes a 'Scopri le offerte' (Discover offers) section with a product image and price.

Amazon.it: elettronica, libri,...

https://www.amazon.it

67%

Cerca

amazon.it

Tutte le categorie

Le serie Amazon Original incluse con Prime
Iscriviti: è gratis per 30 giorni, poi 19,99/anno

Ciao, Accedi
Il mio account

Iscriviti a
Prime

Le tue
Liste

Carrello

fire

Un tablet potente
ad un prezzo incredibile

da 59,99€

kindle paperwhite

Il nostro Kindle più venduto,
oggi ancora migliore

da 129,99€

Amazon utilizza i cookie. [Cosa sono i cookie?](#)

Benvenuto

Accedi per un'esperienza migliore

Accedi in modo sicuro

Sei nuovo/a su Amazon? [Inizia qui](#)

Categorie in evidenza

Fotocamere

Piccoli prezzi

Libri

DVD

Scegli per categoria

Vestiti Donna

Scopri

Feedback annuncio

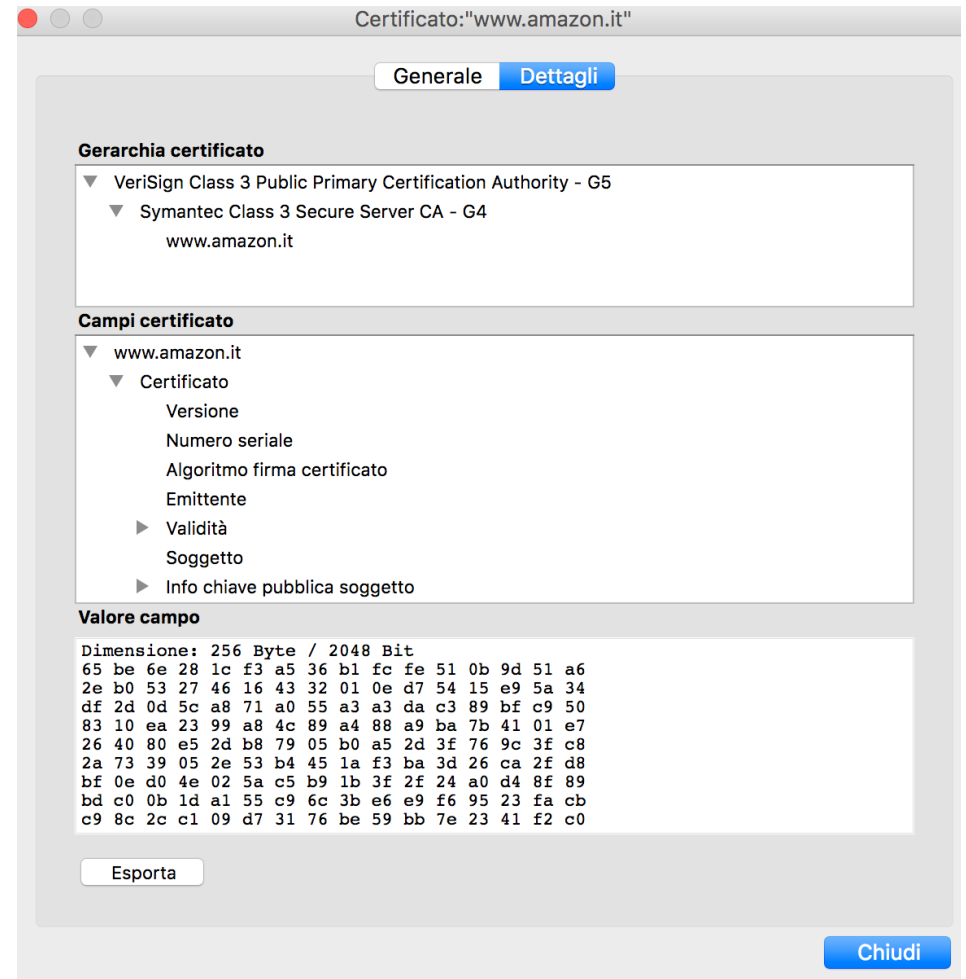
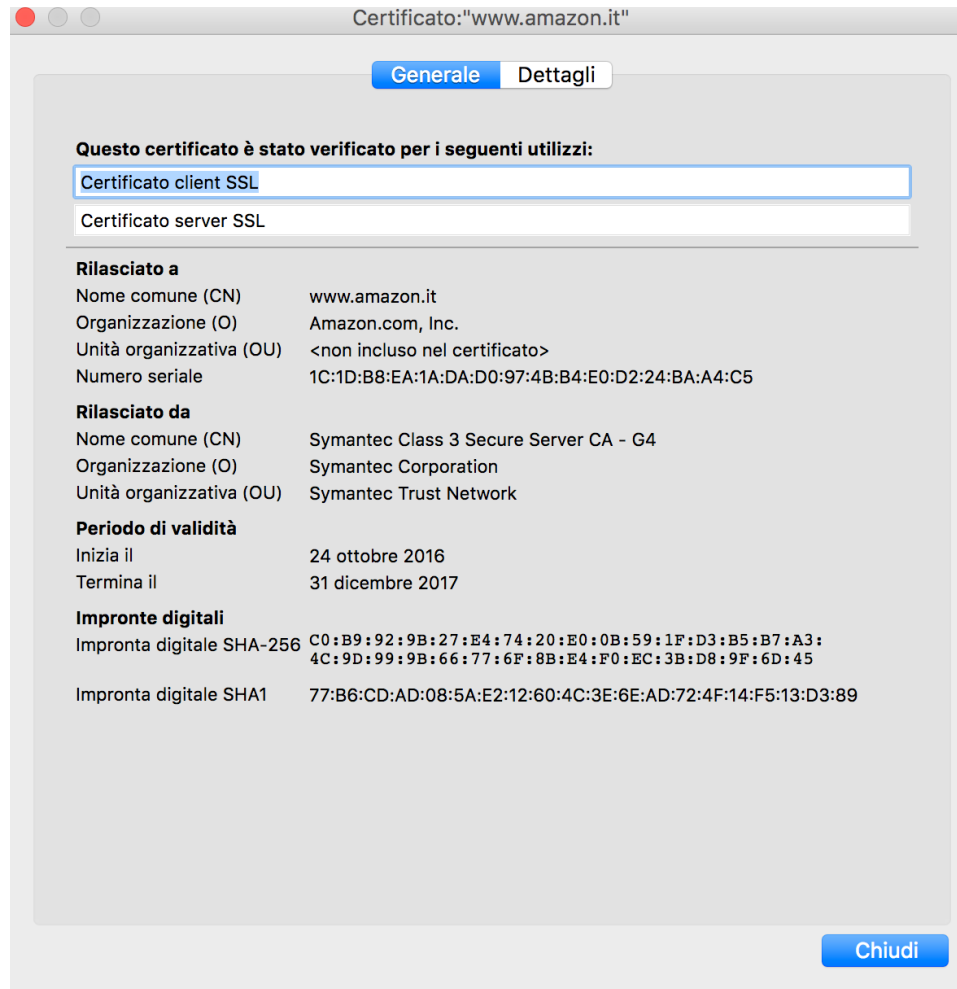
Offerta

34,11 €

Scopri le offerte

Utilizzo di SSL/TLS

HTTPS: pagine WEB sicure

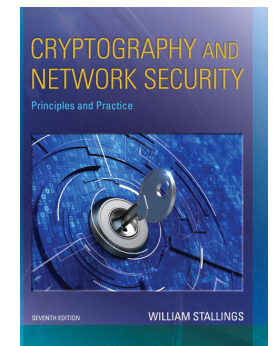


Bibliografia

- **Cryptography and Network Security (Principles and Practice) - Settima Edizione**

by W. Stallings, 2017

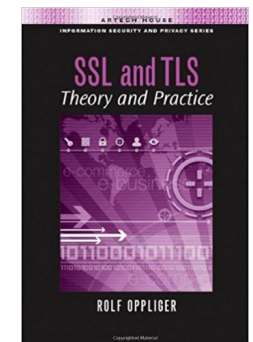
- cap. 17



- **SSL and TLS (Theory and Practice)**

by Rolf Oppliger, 2009

- cap. 3, 4 e 5



Domande?

